

AI-SA-IN-TH-000015

Module 8.1 · LLM Evaluation Fundamentals · AI Safety: Evaluation, Guardrails & Responsible Deployment

Responsible AI Practices

Six Pillars, Ethics Boards, Risk Assessment, HITL, Incident Response, and Governance Maturity

9 min

Duration

B4 – Analyse

Bloom's

L3 – Advanced

Level

Theory

Domain

Learning Objectives

- 1 Define Responsible AI and explain how it differs from AI safety and AI ethics
- 2 Map the six RAI pillars to concrete technical and process controls
- 3 Compare Microsoft, Google, and Anthropic RAI frameworks and identify their structural differences
- 4 Design an AI ethics board with appropriate composition, mandate, and escalation authority
- 5 Apply the pre-deployment risk assessment workflow to a given AI system
- 6 Select the appropriate HITL configuration given a domain, risk level, and regulatory context

What Is Responsible AI?

Responsible AI (RAI)

An interdisciplinary framework for developing and deploying AI systems that are fair, reliable, safe, privacy-preserving, secure, transparent, and accountable — operationalised through governance structures, technical controls, policies, and continuous evaluation processes.

- Broader than AI safety: AI safety focuses on technical safety (preventing harm from model failures); RAI also covers ethics, fairness, transparency, accountability, and societal impact
- Broader than AI ethics: AI ethics is philosophical; RAI translates ethical principles into engineering practices, governance policies, and measurable metrics
- Not a one-time checklist: RAI is a continuous practice — it applies throughout the lifecycle from design and data collection through training, evaluation, deployment, and monitoring
- Increasingly regulatory: EU AI Act, NIST AI RMF, and UK AI Regulation all mandate RAI practices — non-compliance is a legal risk, not just a reputational one
- Business case: RAI reduces liability exposure, increases user trust, avoids brand damage from AI failures, and is increasingly a customer requirement in enterprise procurement

Six Pillars of Responsible AI

1. Fairness

Freedom from bias and discrimination across protected attributes. Measured via demographic parity, equalized odds, fairness audits.

2. Reliability

Consistent, accurate performance across deployment conditions including edge cases, distribution shift, and adversarial inputs.

3. Safety

Prevention of physical, psychological, or societal harm from AI outputs. Includes output guardrails, red teaming, and harm assessment.

4. Privacy

Protection of personal data through data minimisation, differential privacy, federated learning, and compliance with GDPR/CCPA.

5. Security

Defence against adversarial attacks, prompt injection, data poisoning, and model extraction. Requires red teaming and continuous monitoring.

6. Accountability

Clear human ownership of AI decisions. Audit trails, model cards, governance structures, and human-in-the-loop for high-stakes decisions.

RAI Frameworks — Microsoft vs Google vs Anthropic

Framework	Core Principles	Governance Mechanism	Unique Feature	Public Document
Microsoft RAI	Fairness, Reliability/Safety, Privacy/Security, Inclusiveness, Transparency, Accountability	Responsible AI Council + AI, Ethics and Effects in Engineering and Research (AETHER)	Responsible AI Impact Assessment tool; AI Fairness Checklist published	Microsoft RAI Standards (2022)
Google AI Principles	Be socially beneficial, Avoid bias, Be safe, Be accountable, Privacy-preserving, Scientific excellence, Avoid harmful uses	Responsible Innovation teams; People + AI Research (PAIR) group	AI-first ethical design; PAIR Guidebook for practitioners	Google AI Principles (2018, updated 2023)
Anthropic RSP	Safety, Honesty, Harmlessness (Constitutional AI); capability thresholds for deployment decisions	Dedicated safety team + Alignment Science; RSP triggers based on eval results	Responsible Scaling Policy — ties deployment decisions to quantified safety evals	Anthropic RSP v1.0 (2023), updated 2024
NIST AI RMF	Govern, Map, Measure, Manage (GOVERN/MAP/MEASURE/MANAGE)	Voluntary framework for organisations; aligns with ISO/IEC 42001	Risk-tiered approach; sector-neutral; integrates with existing enterprise risk management	NIST AI RMF 1.0 (2023)

AI Ethics Board — Structure and Mandate

AI Ethics Board

A cross-functional governance body with the authority to review, approve, and reject AI system deployments, policies, and practices — providing independent ethical oversight beyond what any single engineering or product team can provide.

- Composition: engineering lead, product/design lead, legal/compliance, HR/people, domain expert (domain-specific), external ethicist or independent member — 5–9 members
- Mandate: review high-risk AI deployments before launch; adjudicate fairness and safety concerns escalated from teams; approve model cards and risk assessments; set organisation-wide AI policy
- Escalation trigger: any AI system in a high-risk EU AI Act category; any system affecting employment, credit, healthcare, education, or law enforcement; any system processing sensitive personal data at scale
- Authority: the ethics board must have genuine veto power — a purely advisory body without enforcement power does not constitute meaningful oversight
- Transparency: meeting minutes, decisions, and dissenting opinions should be documented; consider publishing annual AI ethics reports (as Google, Microsoft, and Anthropic do)

Pre-Deployment Risk Assessment Workflow

1 System Scoping

Define: system purpose, affected populations, decision type (advisory/binding/automated), data sources, deployment context

2 Risk Identification

Map to EU AI Act risk tiers. Identify: bias risks, privacy risks, security risks, hallucination risks, and societal harms

3 Risk Quantification

Measure: fairness metrics, accuracy by subgroup, adversarial robustness, privacy leakage, hallucination rate on held-out set

4 Mitigation Design

For each identified risk: assign owner, design control (technical/process/governance), define residual risk threshold

5 Ethics Board Review

Present assessment to ethics board. Obtain approval for deployment or escalation to senior leadership if residual risk is high

6 Deploy + Monitor

Launch with monitoring for bias drift, safety incidents, and performance degradation. Schedule re-assessment quarterly

Model Cards vs System Cards

Model Card

- Documents a single ML model (weights + architecture)
- Covers: intended use, performance benchmarks, limitations, biases, training data summary
- Created by: model developer/trainer
- Granularity: model-level — describes the capability of the weights, not the deployment context
- Standard: Mitchell et al. (2019); adopted by HuggingFace, Google, Anthropic
- Required under: EU AI Act Article 13 for high-risk AI technical documentation

System Card

- Documents an entire AI product/deployment (model + prompts + retrieval + tools + UI)
- Covers: system purpose, safety evaluations, red team findings, limitations, intended users, misuse potential
- Created by: system deployer/product team
- Granularity: deployment-level — describes the full system a user interacts with
- Standard: Meta introduced for Llama 2 (2023); adopted by Microsoft (Copilot), OpenAI (ChatGPT)
- Required under: EU AI Act Article 13 transparency documentation for deployed high-risk systems

Human-in-the-Loop — When It Is Mandatory

Human-in-the-Loop (HITL)

A design pattern in which a human reviews, approves, or corrects AI system decisions before they take effect — providing oversight for decisions that carry risk, require ethical judgment, or affect individual rights.

- GDPR Article 22: a right not to be subject to fully automated decisions with legal or similarly significant effects — a human review option must exist
- EU AI Act Article 14: high-risk AI systems must allow human oversight, including ability to disregard, override, or intervene
- Three HITL modes: (1) Human-in-the-loop: human reviews every AI recommendation before action; (2) Human-on-the-loop: human monitors and can intervene; AI acts autonomously; (3) Human-in-command: human sets overall objectives; AI operates independently within them
- Risk-based selection: mode 1 for safety-critical (medical prescriptions, criminal sentencing); mode 2 for medium-risk (fraud detection, content moderation); mode 3 for low-risk (spam filtering, product recommendations)
- Automation bias risk: even with HITL, humans often defer to AI recommendations — design HITL interfaces to encourage genuine independent judgment

HITL Configuration by Risk Level and Domain

Risk Level	HITL Mode	Domain Examples	Review Requirement	Legal Basis
Critical	Human-in-the-Loop (Mode 1)	Medical diagnosis, criminal sentencing, child protection removal	100% human review before action	GDPR Art 22; EU AI Act Art 14; professional licensing law
High	Human-in-the-Loop (Mode 1)	Hiring decisions, loan approvals, insurance underwriting	Human review for all borderline decisions; appeal right	ECOA; Fair Housing Act; GDPR Art 22
Medium	Human-on-the-Loop (Mode 2)	Fraud detection, content moderation, benefits eligibility	Human monitors; can override; sampled audit of auto-decisions	EU AI Act Art 14; internal policy
Low	Human-in-Command (Mode 3)	Product recommendations, spam filter, autocomplete	Periodic accuracy audits; user feedback mechanism	No mandatory HITL; privacy compliance still required

Incident Response Plan for AI Failures

AI Incident Response Plan

A documented playbook specifying how an organisation detects, triages, investigates, mitigates, and learns from AI system failures — including misuse, unintended harm, safety incidents, bias events, and data breaches involving AI-generated content.

- Severity levels: P0 (imminent physical harm or active data breach — respond in minutes); P1 (significant bias/hallucination reaching many users — respond in hours); P2 (quality degradation — respond within 24h); P3 (minor issues — respond within 1 week)
- Detection: production monitoring for anomalous block rates, bias metric drift, user complaint spikes, and external reports
- Response: P0/P1 requires ability to roll back model version within 1 hour or disable AI feature; designated incident commander with authority to take system offline
- Root cause analysis: every P0/P1 requires a written post-mortem within 5 business days including timeline, root cause, contributing factors, and preventive actions
- Notification obligations: GDPR Article 33 requires notifying regulator within 72 hours of a personal data breach — AI incidents involving PII leakage trigger this obligation

AI Governance Maturity Model — Five Levels

L1	Ad Hoc	No formal AI governance. Deployments happen without systematic risk assessment. Ethics addressed reactively after incidents.
L2	Developing	Basic policies exist. Some fairness and safety reviews. No dedicated ethics function. Compliance-driven.
L3	Defined	Formal RAI framework adopted. Ethics board established. Pre-deployment risk assessments conducted. Model cards published.
L4	Managed	Metrics-driven RAI. Fairness monitoring in production. HITL configurations standardised. Third-party audits conducted.
L5	Optimising	RAI embedded in culture. Continuous improvement. External transparency reports. RAI innovation (novel safety research).

Most organisations are at L2–L3 as of 2025. EU AI Act compliance requires at least L3 for high-risk AI systems.

Case Study — Anthropic's Responsible Scaling Policy

Case: Anthropic Responsible Scaling Policy (RSP) v1.0 — September 2023

- The RSP is a self-imposed policy that ties Anthropic's ability to develop and deploy more powerful AI models to demonstrating that safety measures scale alongside capability
- AI Safety Levels (ASLs): ASL-1 (no risk), ASL-2 (current Claude-level — basic uplift mitigations required), ASL-3 (significant uplift risk — classified capability evals required, enhanced security, access restrictions), ASL-4 (not yet reached — would require unprecedented safety measures)
- Required capabilities evaluations before ASL-3: model must be tested for CBRN uplift (chemical, biological, radiological, nuclear), cyberoffensive capability, and autonomous replication
- Deployment commitment: if a model reaches ASL-3 capability thresholds, Anthropic commits to not deploying until adequate safeguards are demonstrated
- Transparency: RSP is publicly documented — external researchers can hold Anthropic accountable to its stated commitments

Key Lesson

The RSP represents one of the first attempts to operationalise responsible scaling: connecting capability growth to concrete safety thresholds rather than relying on good intentions alone. Its core innovation is that safety obligations are triggered by measured capability levels, not by arbitrary deployment timelines. Updated RSP v1.5 (2024) added more specific evaluation criteria and clearer ASL-3 thresholds.

Responsible AI Procurement Checklist

Questions every organisation should ask when procuring or deploying third-party AI:

- Model card & system card: does the vendor publish a model card or system card covering intended use, performance benchmarks, known limitations, and bias evaluation results across demographic subgroups?
- Bias and fairness audit: has the system been independently audited for demographic parity gaps and equalized odds across the protected attributes relevant to your use case? What were the results?
- Data governance: what data was used to train the model? Does the vendor have a documented data retention and deletion policy? Are training data sources disclosed?
- Human-in-the-loop: does the system support a human review pathway for high-risk decisions? Can you configure HITL thresholds? Is there an appeals mechanism for affected individuals?
- Incident response: does the vendor have a documented AI incident response plan? What is the SLA for responding to safety or bias incidents discovered in production? How are you notified?
- Regulatory compliance: is the system compliant with EU AI Act, GDPR, and applicable sector-specific regulations? Does the vendor provide a Data Processing Agreement? Is their AI Act conformity assessment available?

Societal Impact Assessment — Worked Template

Structured assessment for a customer service LLM deployment at a major bank

Section 1: Affected Populations

Direct users: 2M bank customers who interact with the chatbot

Potentially harmed groups: elderly users with low digital literacy; non-English speakers (chatbot English-only at launch); customers with cognitive disabilities; customers in financial distress seeking debt advice

Special concern: customers in financial difficulty may receive responses that could affect mental health — chatbot must never provide financial advice without human escalation pathway

Section 2: Potential Harms & Mitigations

Risk 1 (HIGH): Chatbot gives incorrect account balance or transaction advice → Customer makes wrong financial decision

Mitigation: All balance/transaction queries → verified account API, never from model knowledge; human escalation for disputed amounts

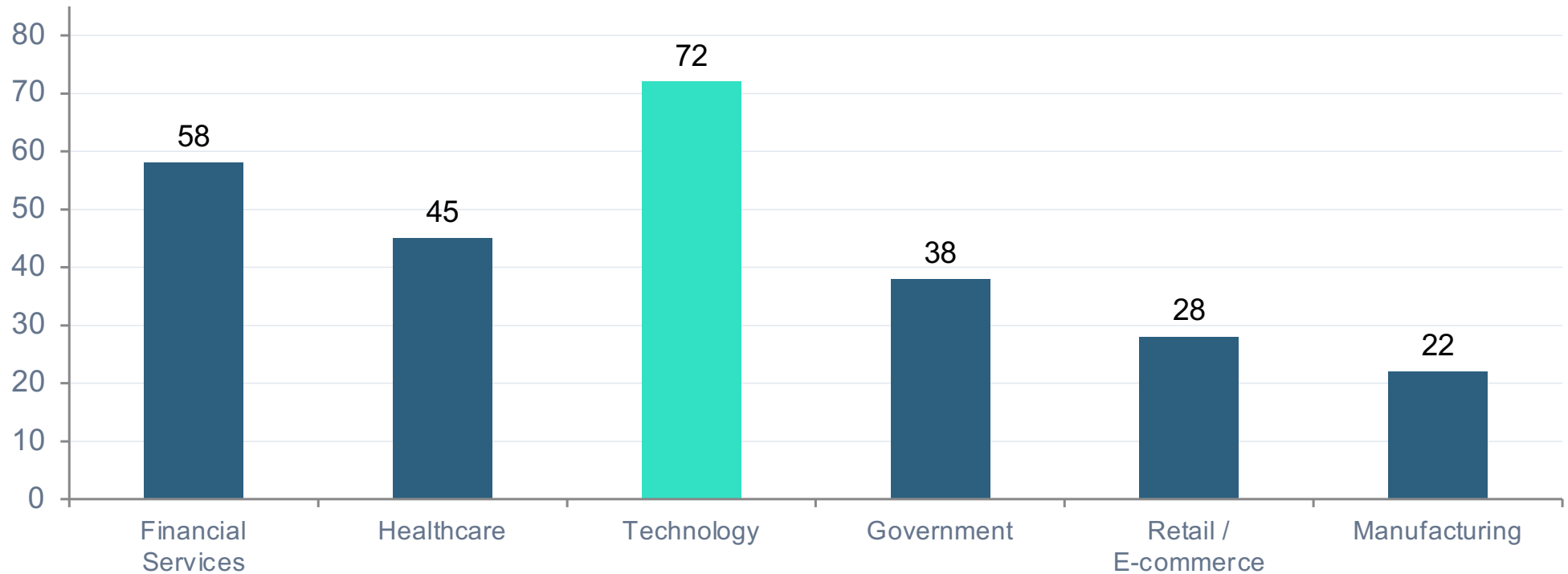
Risk 2 (MEDIUM): Chatbot fails to escalate debt/distress signals → Customer in crisis receives inadequate support

Mitigation: Topic classifier detects distress keywords → mandatory human agent handoff within 30 seconds

Risk 3 (LOW): Chatbot language too complex for low-literacy users

Mitigation: Flesch-Kincaid reading level check on outputs → simplify if above Grade 8

RAI Adoption Maturity Across Industry Sectors (2025)



Source: KPMG AI Governance Survey 2025. Technology sector leads due to regulatory pressure and talent availability. Manufacturing and retail lag significantly. EU AI Act enforcement (full application from 2026) is expected to raise Financial Services and Healthcare to 75%+ within 24 months.

Key Takeaways

AI-SA-IN-TH-000015

- 1 Responsible AI is broader than safety: it operationalises six pillars (fairness, reliability, safety, privacy, security, accountability) through governance structures, technical controls, and measurable metrics
- 2 AI ethics boards must have genuine veto authority — purely advisory bodies without enforcement power do not constitute meaningful oversight under the EU AI Act's human oversight requirements
- 3 The pre-deployment risk assessment is a six-step process: scope → identify risks → quantify → design mitigations → ethics board review → deploy with monitoring — shortcuts at any step create legal and reputational exposure
- 4 HITL mode selection must match risk level: Mode 1 (human reviews every decision) for medical/criminal/hiring; Mode 2 (human monitors, can override) for fraud/content moderation; Mode 3 (human sets objectives) for low-risk applications
- 5 Anthropic's Responsible Scaling Policy operationalises responsible scaling by tying deployment decisions to quantified safety evaluation thresholds — the first industry attempt to make capability-safety tradeoffs explicit and publicly accountable